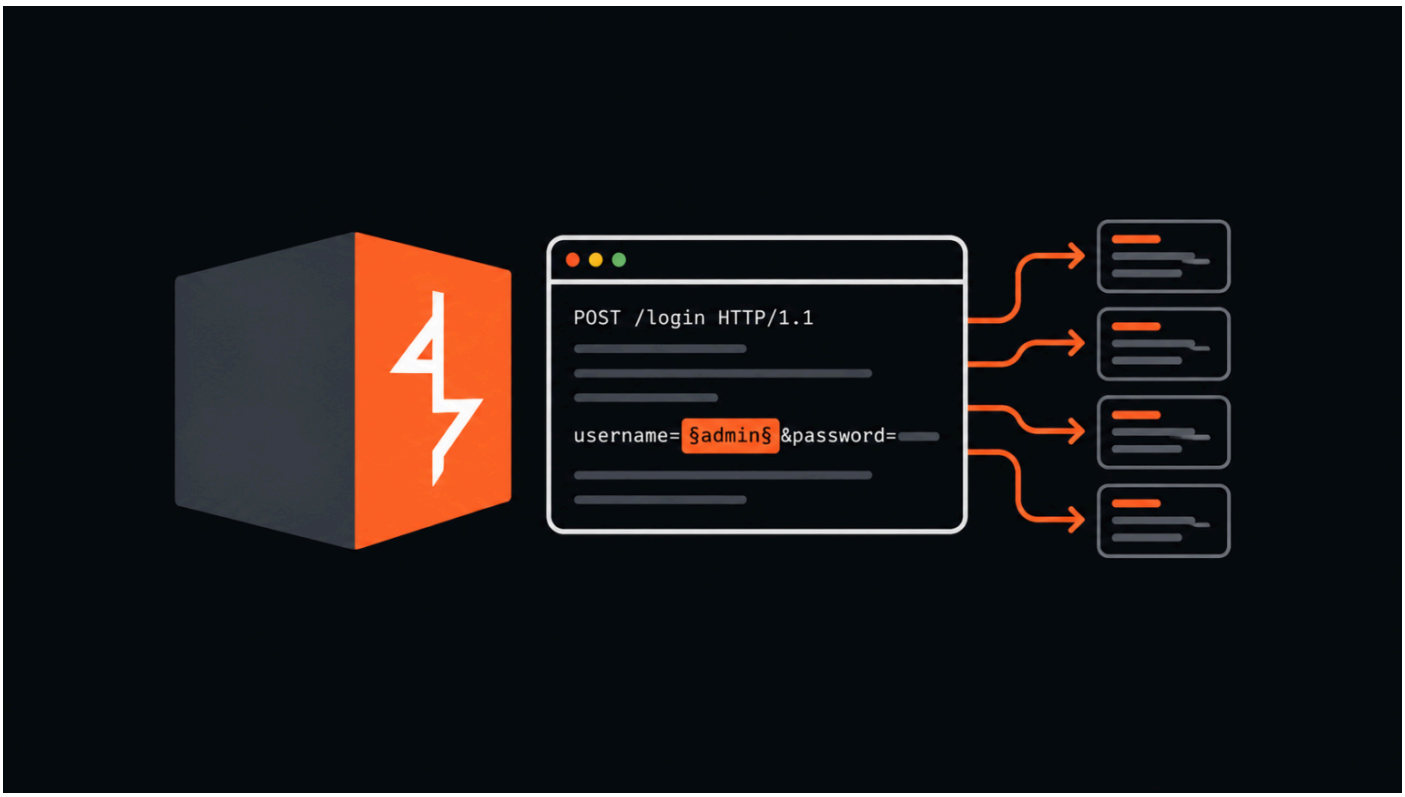
, чтобы начать свой путь в сфере
уже сегодня!

Узнать больше

Руководство по использованию Intruder в Burp Suite: как использовать Intruder



Введение

При тестировании веб-приложения может быть полезно менять по одному параметру за раз, но этот процесс замедляется, когда нужно протестировать десятки или сотни значений. Наприм

азному при вводе правильного и

ную заняла бы много времени.

веб-безопасности, который автоматизирует
чения, которые хотите протестировать,
ге Intruder отправлять запросы с разными
значениями. Затем вы можете сравнить ответы, чтобы выявить необычное поведение.

Intruder обычно используется для:

- Тестирование проверки входных данных.
- Определение действительных имен пользователей или других идентификаторов в авторизованных средах.
- Тестирование обработки параметров и логики приложения.
- Фаззинг входных данных для выявления неожиданных ответов.
- Оценка механизмов аутентификации в ходе контролируемых тестов.

1. Что такое Burp Suite Intruder?

Если вы только знакомитесь с Burp Suite, начните с нашей **шпаргалки по Burp Suite**, в которой кратко описаны Proxy, Repeater, Intruder и другие инструменты, используемые при тестировании веб-приложений.

Burp Suite — это набор инструментов для тестирования безопасности веб-приложений. Инструмент Proxy позволяет перехватывать HTTP-трафик, Repeater — изменять и повторно отправлять отдельные запросы, а Intruder — автоматизировать повторные запросы с разными входными значениями.
Предположим, при тестировании страницы входа вы перехватили следующий HTTP-запрос:

```
POST /login HTTP/1.1
Host: example.test
Content-Type: application/x-www-form-urlencoded

username=testuser&password=wrongpass
```

ые имена пользователей. Без Intruder вам
равлять запрос, изучать ответ и повторять
вы можете указать имя пользователя в
список, например:

Intruder отправляет запросы с использованием этих значений и отображает полученные ответы в виде таблицы. Вы можете отсортировать результаты по коду состояния, длине ответа и другим доступным полям.

Когда следует использовать Intruder вместо Repeater?

Пошаговое руководство по изменению и повторной отправке HTTP-запросов вручную см. в нашем **руководстве по использованию Burp Suite Repeater**. Repeater особенно полезен для изучения отдельных запросов перед переходом к автоматизированному тестированию с помощью Intruder.

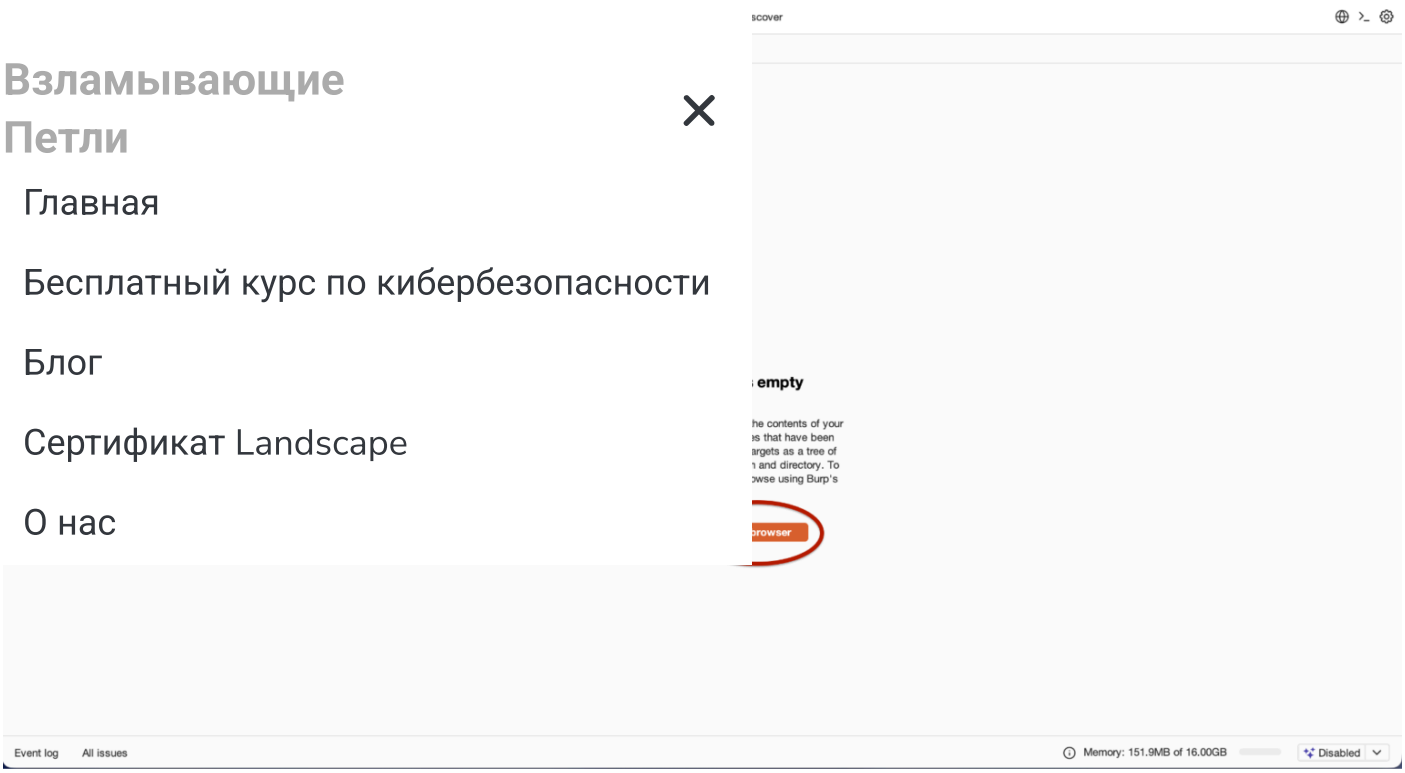
Используйте Repeater, если вы хотите протестировать небольшое количество изменений и внимательно проверить реакцию на каждое из них.
Используйте Intruder, когда хотите систематически проверять несколько значений и сравнивать ответы.
Например:

- Репитер: измените id=10 на id=11 и проверьте результат.
- Злоумышленник: протестируйте идентификаторы от 1 до 100 и найдите различия в ответах.

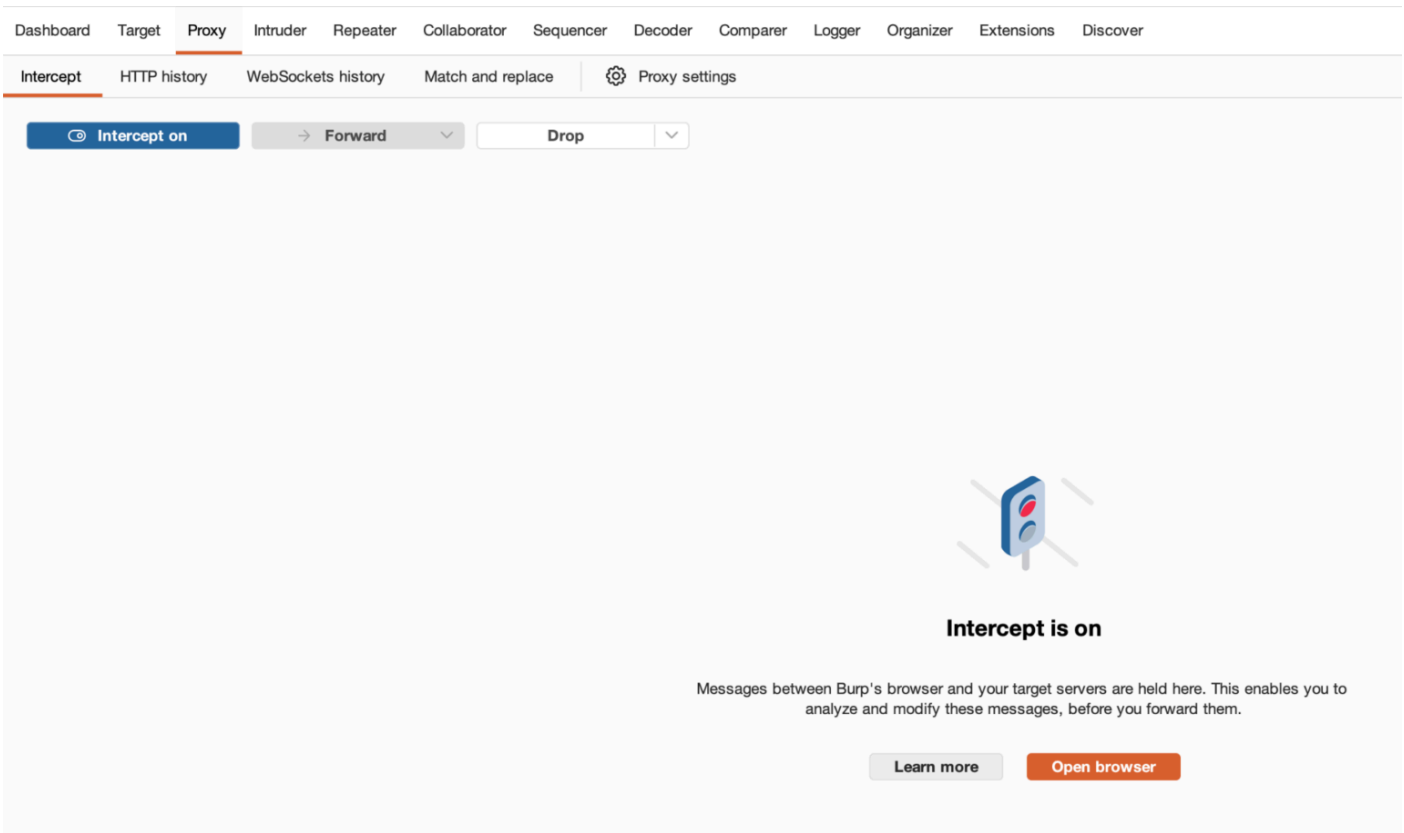
Intruder не доказывает автоматически наличие уязвимости. Он помогает выявить интересное поведение, требующее дальнейшего изучения.

2. Как отправить запрос в Intruder

Прежде чем начать, установите Burp Suite Community Edition и откройте встроенный браузер.



И включите перехват на вкладке прокси



Шаг 1. Откройте целевую страницу

Откройте страницу, которую вы хотите протестировать на наличие уязвимостей. Допустим, это страница входа.

Шаг 2. Сгенерируйте запрос на вход в систему

Откройте страницу входа в лабораторию и введите неверные имя пользователя и пароль.

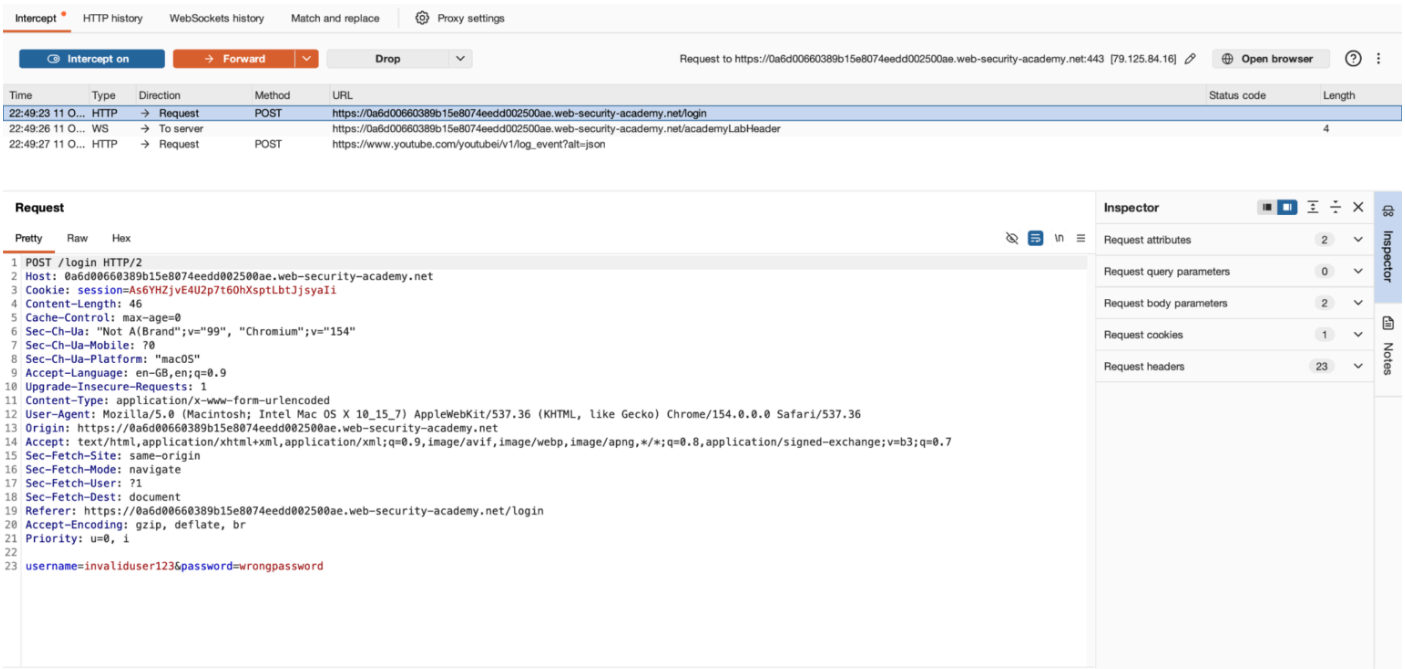
Например, введите:

Имя пользователя: invaliduser123

Пароль: wrongpassword

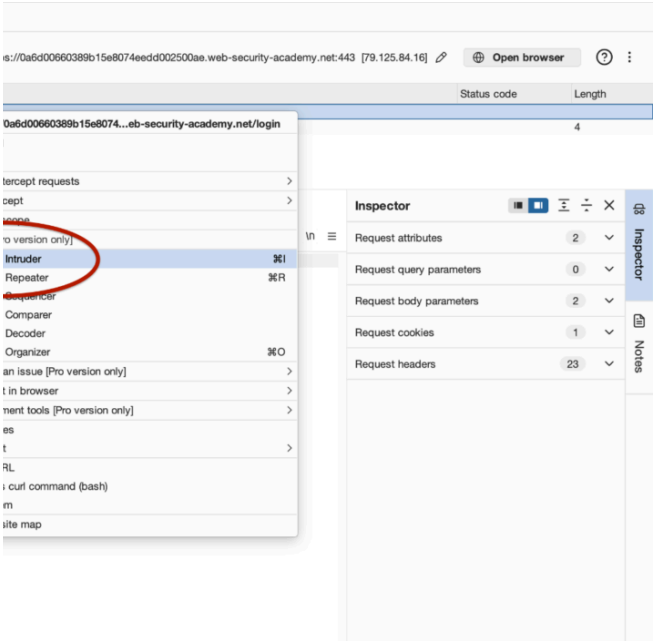
Отправьте форму.

Burp Suite должен записать полученный HTTP-запрос.



Шаг 3. Отправьте запрос в Intruder

Щелкните правой кнопкой мыши по запросу и выберите «Отправить в Intruder»



Теперь откройте вкладку «Нарушитель».

Burp создает конфигурацию атаки на основе перехваченного запроса. Вы можете выбрать позиции ввода, тип атаки и настроить полезные данные. Этот подход удобен тем, что исходный запрос уже содержит необходимые заголовки, параметры и информацию о сеансе.

3. Определение позиций нарушителя

Позиции полезной нагрузки определяют, куда именно Intruder вставляет новые значения в запрос. Когда вы отправляете запрос в Intruder, Burp может автоматически пометить некоторые значения. Перед началом атаки всегда проверяйте эти позиции.
Позиция полезной нагрузки обозначается символом “`§“`. Рассмотрим следующий пример:

```
POST /login HTTP/2
Host: 0a6d00660389b15e8074eedd002500ae.web-security-academy.net
username=§invaliduser123§&password=wrongpassword
```

Маркеры указывают на то, что Intruder должен заменить invaliduser123 на каждую полезную нагрузку. Например, если полезная нагрузка — admin, запрос будет выглядеть так:

```
имя пользователя = администратор и пароль = неправильный пароль
```

Если в качестве полезной нагрузки используется alice, то получается:

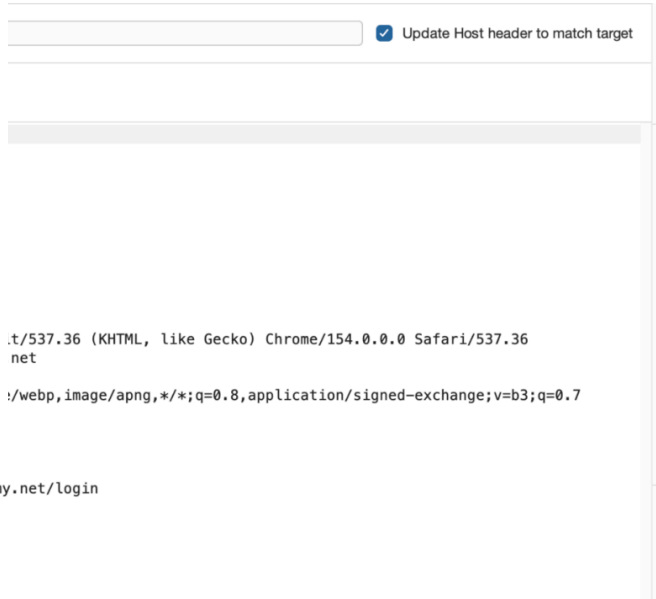
```
имя пользователя=alice&пароль=wrongpassword
```

Пароль не изменился, так как он находится за пределами отмеченной позиции.

Как выбрать, какие именно значения нужно изменить

В редакторе запросов Intruder:

тически выбранные позиции.



- Выделите только то значение, которое хотите проверить.
- Нажмите «Добавить §», чтобы пометить выделенный текст.
- Убедитесь, что маркеры окружают только нужное значение.

Для проверки имени пользователя выберите только значение имени пользователя. Вы также можете отметить несколько позиций, если этого требует выбранный тип атаки. Например:

```
имя пользователя=§testuser§&пароль=§wrongpassword§
```

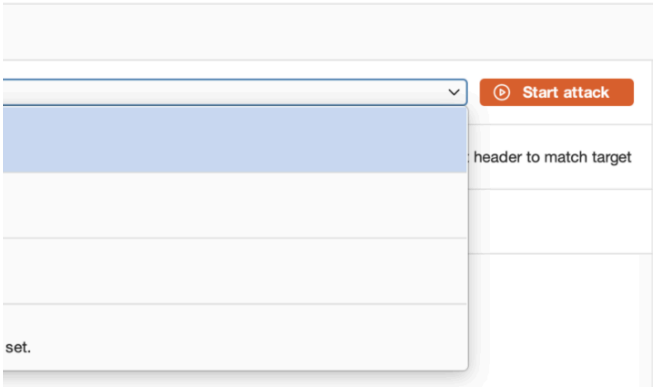
Это определяет две позиции полезной нагрузки. Маркеры § — это визуальные индикаторы, используемые Intruder. Обычно они не отправляются на сервер как часть фактического значения параметра. Очень важно правильно выбрать позицию. Если вы укажете не тот раздел, Intruder может отправить некорректные запросы или протестировать что-то, что не соответствует вашим ожиданиям.

4. Типы атак Burp Intruder

Burp Intruder поддерживает четыре традиционных типа атак

1. Снайпер
2. Таран
3. Вилы
4. Кассетная бомба

Каждый тип атаки определяет способ внедрения полезной нагрузки в отмеченные позиции.



ования отдельных параметров. Он использует один набор полезных данных и по очереди вставляет их в каждую отмеченную позицию. Остальные позиции сохраняют свои исходные значения. Рассмотрим этот запрос:

```
имя пользователя=§testuser§&пароль=§wrongpassword§
```

Предположим, что список полезных нагрузок выглядит так:

- admin
- alice
- guest

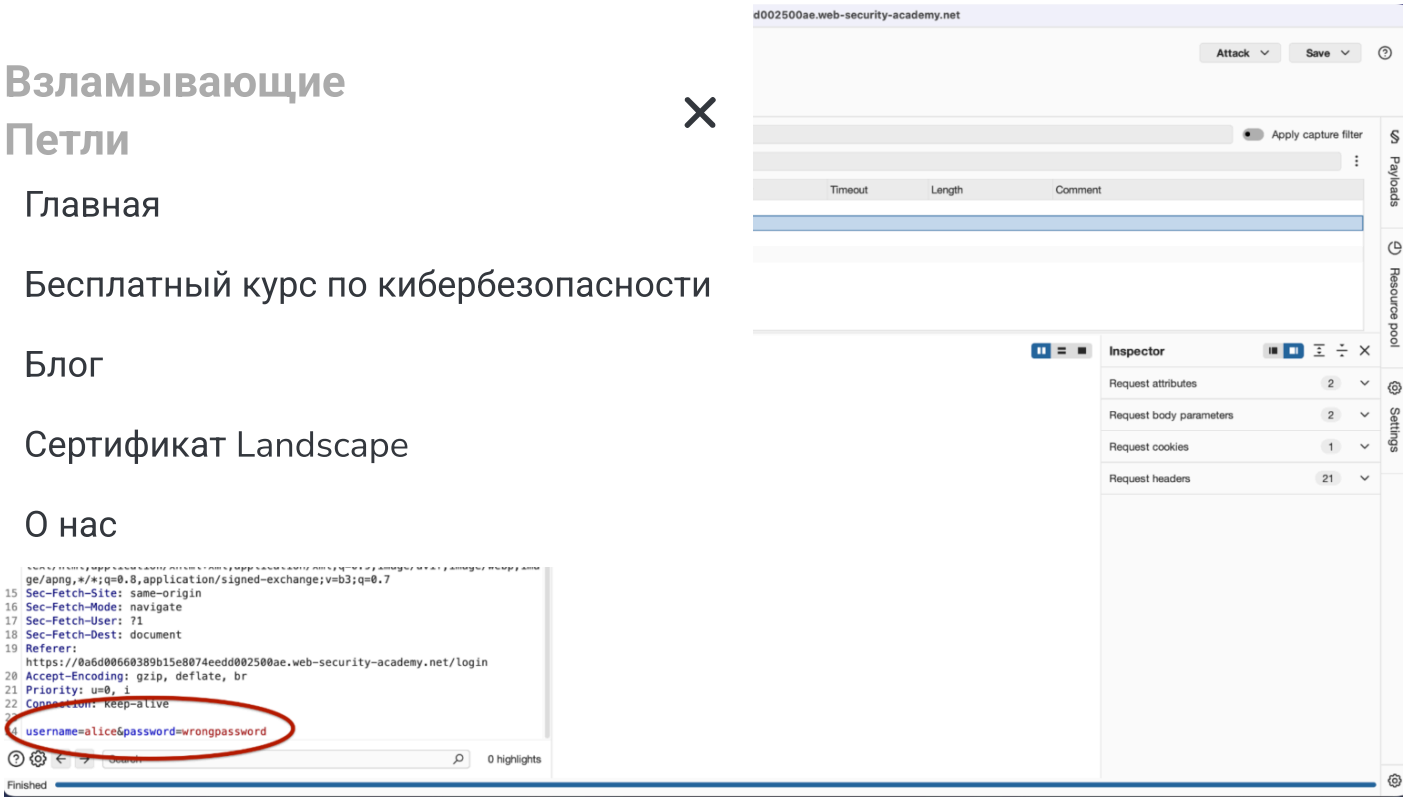
Intruder сначала проверяет правильность введенного имени пользователя:

```
username=admin&password=wrongpassword
username=alice&password=wrongpassword
username=guest&password=wrongpassword
```

Затем он проверяет расположение пароля, используя тот же список полезных данных:

```
username=testuser&password=admin
username=testuser&password=alice
username=testuser&password=guest
```

При использовании двух позиций и трех полезных нагрузок Sniper генерирует шесть запросов, не считая необязательного базового запроса.
В нашем примере, поскольку мы проводили атаку с тремя полезными нагрузками, мы видим, как Burp Intruder заменил полезную нагрузку в нужном месте



4.2 Атака «таран»

Атака «таран» также использует один набор полезных данных, но при этом в каждую отмеченную позицию одновременно вставляется один и тот же набор. Предположим, что запрос

```
имя пользователя=§test§&пароль=§test§
```

Список полезной нагрузки выглядит следующим образом:

- admin
- alice
- guest

Злоумышленник генерирует:

```
username=admin&password=admin
username=alice&password=alice
username=guest&password=guest
```

Обе позиции получают одинаковое вознаграждение за каждый запрос.

4.3 Атака Pitchfork

Pitchfork использует несколько наборов полезных данных и вставляет соответствующие полезные данные в несколько позиций.
Представьте, что вы хотите протестировать совпадающие пары имен пользователей и паролей в лаборатории.
В первой позиции используется следующий набор полезных данных:

- Алиса
- Боб
- Чарли

Во втором положении используется этот набор полезной нагрузки:

- пароль1
- пароль2
- пароль3

Вилы производят:

```
username=alice&password=password1
username=bob&password=password2
username=charlie&password=password3
```

Первый элемент из каждого списка используется вместе со вторым, затем с третьим.

4.4 Атака кассетной бомбой

Кассетная бомба использует несколько наборов полезных данных и проверяет комбинации их значений. Предположим, что запрос содержит две отмеченные позиции:

```
имя пользователя=§testuser§&пароль=§testpass§
```

alice / pass2
alice / pass3
bob / pass1
bob / pass2
bob / pass3

Общее количество запросов равно произведению количества полезных данных в каждом наборе. В этом примере 2 имени пользователя × 3 пароля = 6 запросов, что может занять очень много времени. Кластерная бомба может генерировать большое количество запросов. Например, 100 имен пользователей и 1000 паролей могут дать 100 000 комбинаций.

5. Настройка полезной нагрузки Intruder

Payloads — это значения, которые Intruder подставляет в выбранные позиции. После настройки позиций откройте раздел Payloads. Вы можете выбрать тип полезной нагрузки и настроить значения, которые будет использовать Burp.

5.1 Простой список

Простой список — один из самых полезных типов полезной нагрузки для начинающих. Он позволяет вводить значения вручную, вставлять список или загружать значения из файла. Например, для базового теста проверки входных данных:

- hello
- 123
- -1
- 0
- 999999
- test

Для перечисления имён пользователей можно использовать:

- invaliduser123

данных.

и вы скопировали несколько значений и хотите вставить их в список, просто нажмите «Вставить», и все эти значения будут вставлены.

5. Убедитесь, что тип атаки соответствует вашему тесту.

Для проверки одного параметра обычно достаточно простого списка.

5.2 Числа

Злоумышленник также может автоматически генерировать числовые полезные нагрузки. Например, предположим, что вы хотите протестировать числовой параметр, такой как:

```
productId=§100§
```

Вы можете сгенерировать значения от 1 до 20.
Чтобы настроить его, выберите тип полезной нагрузки Numbers и укажите диапазон, размер шага и другие доступные параметры. Числовые полезные нагрузки полезны для тестирования идентификаторов, параметров разбивки на страницы, количества и граничных значений. Числовая последовательность может помочь выявить неожиданное поведение системы, но другой ответ не означает автоматически, что контроль доступа нарушен. Ответ необходимо интерпретировать в контексте.

ка

уязвимую лабораторию PortSwigger

ировать, как Intruder может выявлять

s while keeping the password

to determine whether the application

id usernames.

Once we identify an interesting response, we'll investigate it further using a separate test with a fixed username.

The goal is to understand how response differences can reveal weaknesses in authentication behavior during an authorized security assessment.

We can see that the application is giving us information "Invalid username or password." for every response. So a trick here could be to check if all the responses contain this string. If some response misses this then we can check it deeper. While reviewing the responses, we can see that one response did not give us the string match. And upon closely checking, we see it does have almost the same string but one " " is missing

So it looks like the username “oracle” produced a different response which is good for further testing. Now, we will use the other attack to use “oracle” as our username and passwords supplied from the list.

Now we know all responses will generate a string “Invalid username or password” so we should look for a response that does not have this string. While reviewing the response, we can across one with different response

Which makes it clear that we found the correct credentials. So our username was “oracle” and password was “iloveyou”

7. How to Analyze Intruder Results

Running an attack is only half the work. The real value comes from understanding why responses differ. Burp Intruder displays useful response information in a table. Start by comparing the following indicators.

7.1 HTTP status code

The HTTP status code indicates the broad outcome of a request. Examples include:

- 200 OK: The server returned a successful HTTP response.
- 302 Found: The server redirected the client.
- 400 Bad Request: The server rejected the request as malformed.
- 401 Unauthorized: Authentication is required or was not accepted.
- 403 Forbidden: The server refused the request.
- 404 Not Found: The requested resource was not found.

ıple, an application can return 200 OK even when
in page and an error message.
ı the normal baseline response.

fy unusual results. Suppose your results look like

The last response is 28 bytes longer.
That difference deserves investigation, but it does not prove that candidate4 is valid. The response might include a different error message, a changing token, a timestamp, or other dynamic content.
Open the response and identify the actual reason for the difference.

7.3 Differences in response content

Response content is often more useful than the status code or length alone.
Look for:

- Different error messages.
- Unexpected content appearing in the response.
- Missing or additional fields.
- A redirect destination that changes.
- A different application state or page.

For our username-enumeration example, comparing the actual error messages was the key step.

8. Burp Suite Community vs Professional Intruder

Burp Suite Community Edition is suitable for learning Intruder and performing manual security testing. However, it does not provide the full Intruder functionality available in Professional.
PortSwigger describes Community Edition's Intruder as a demo version. The Professional edition includes the full attack functionality and additional capabilities.

- Capture requests in Proxy: Community Edition = Yes, Professional = Yes
- Send requests to Intruder: Community Edition = Yes, Professional = Yes
- Configure and inspect positions: Community Edition = Available, Professional = Available
- Perform basic learning exercises: Community Edition = Yes, Professional = Yes
- Full Intruder attack functionality: Community Edition = Limited demo, Professional = Yes
- Professional vulnerability scanner: Community Edition = No, Professional = Yes
- Save project files: Community Edition = No, Professional = Yes

mmunity Edition = Limited, Professional =

ve HTTP testing while giving you control over

ed to those positions.
sual application behavior.

Sniper is a strong starting point for testing individual inputs. Battering ram repeats one value across several positions, Pitchfork pairs values from different lists, and Cluster bomb tests every combination.
It is not necessary to master every Intruder feature immediately. Start with small payload lists and simple requests, learn to read the results carefully, and move to more complex attack types as understanding improves. The goal is not simply to send more requests. It is to use controlled testing to discover meaningful differences in how a web application behaves. Happy Hacking !!!

Взламывающие Петли

Главная

Бесплатный курс по кибербезопасности

Блог

Сертификат Landscape

О нас

This was created for those who want to obtain a lucrative career in cybersecurity. Get this free guide delivered to your email that will show you step-by-step how to get into cybersecurity.

Quick Link

Home

About Us

Membership

Blog

Contact Us

Contact Detail

500 Westover Dr #8208, Sanford, NC 27330

Взламывающие Петли